

Solutions Dimension — Facilitator Quick Reference

p1 how to run it · p2 when to intervene · p3 web version · p4 scenario index · Full detail in the Manual

The one thing to understand

The disagreement is the lesson. Students learning card definitions is a side effect. The activity works when a team argues about which of two defensible options is better and has to say why. **A session where everyone agreed quickly did not work.** No security expertise is needed to facilitate.

Setup

- Teams of **2–3**. Four is the maximum before someone stops talking.
- Per team: original 4-dimension deck, Solutions deck, printed 3×3 risk matrix, **6 physical tokens**, record sheet.
- Sort Solutions into piles before you start: Foundational (1–13), Extended (14–18), Advanced (19–21), modifiers (22–28).
- Use real tokens, not a tally. Spending must be visible and irreversible.
- Explain Phase 1 only, then start.** Explain each later phase when teams reach it. Front-loading all three confuses everyone.

Costs

Tier	Cost	Cards
Foundational	1	1–13
Extended	2	14–18
Advanced	3	19–21
Modifiers	0	22–28

Budget **6 tokens**. Deal **8 control cards + 3 modifiers**: six Foundational, one Extended, one Advanced. **Every hand is guaranteed** to contain a card that addresses the drawn threat, and all teams get the same eight unless you switch to *Vary by team*. Nobody should be punished for a deal.

Timing (35–45 min total)

Setup and rules	5–7
Phase 1: threat and placement	5–7
Phase 2: budgeted defense	8–10
Phase 3: residual risk	4–5
Cross-team comparison	5–8
Debrief	5–10

Phase 1 — Threat Model and Placement

Draw one card from each of the four original dimensions. Build a scenario where all four are true. Place on the matrix. Record the coordinates.

“Build a story where all four of these are true at once. Every card has to do some work in it.”

Severity rule. They must justify severity by pointing at the **Human Impact card** and naming who is harmed. Novices rate severity by how sophisticated an attack *sounds*; this corrects it without a lecture.

Axes. Severity runs across, likelihood runs down. Controls that work move the marker *up*, not left.

Phase 2 — Budgeted Defense

First, both arms list the measures they would recommend, *including what they cannot afford*. Then deal 8 Solutions + 3 modifiers and give 6 tokens. For each purchase they say which safeguard addresses which part of the threat.

“Six tokens. Anything you don’t spend is gone. For each card, tell me which part of your scenario it touches.”

Enforce the arithmetic instantly. A team that overspends unnoticed has not played the game.

Phase 3 — Residual Risk

Same threat, same board, re-placed given what they bought. They state what still gets through.

“Where does it sit now? And tell me what still gets through, because something does.”

Then compare teams. Don’t skip it. The question is never who was right — it’s why two reasonable groups bought different things.

Adjudicating modifier cards — the one-sentence test

Modifiers are free, so each demands a justification. **Each card asks a different question** and hands the team a sentence with blanks to fill. If unsure, ask once: *“Can you say that again naming a specific person, system, or failure?”* Specific → accept. Still general after **one** prompt → card returns to the deck. Don’t prompt twice.

The quick read: an answer that still reads like the frame, with the blanks filled by generalities, is the reject case. An answer that abandons the frame and says something specific is fine — the frame is scaffolding, not a form.

Accept: “Staff will share the one MFA phone at the front desk.” **Reject:** “People are the weakest link.”

Accept: “The exec director owns that decision, reviewed in twelve months.” **Reject:** “We accept the rest of the risks.”

Also: **max 2 modifiers per round**; card 24 needs Identity & Access Management or Account Lifecycle Management bought first; card 26 is played *instead of* a purchase.

Debrief — pick 3 or 4

- Which purchase did you argue about most, and how did you settle it?
- What did you want and couldn’t afford? What would you tell the client about that gap?
- Did anything you bought only help *after* the attack succeeded? Worth the points?
- Two teams bought differently for similar threats. Why?
- Which card would you cut from this deck entirely?

Misconceptions worth naming

- Controls *reduce* risk; they don’t remove it. (That’s Phase 3.)
- Expensive $\neq$ better. Cost tracks CIS Implementation Group, not value.
- Awareness training is one anti-phishing layer; email filtering (12) is cheaper and doesn’t depend on a tired person at 4pm.
- Backups limit consequence; the data is still disclosed.
- Not everything must be fixed. Four treatments: avoid, mitigate, transfer (21), accept (26).

When to Intervene

Your default is NON-intervention

New facilitators intervene far too early. A team silent for 30 seconds is thinking. A team arguing is learning. A team corrected by a peer has learned more than one corrected by you. **Your standing job is small:** keep time, enforce budget arithmetic, adjudicate modifiers, and handle the four red-flag situations below. Everything else is optional and most of it is counterproductive.

The escalation ladder — use the lightest rung that works, then stop.

Rung 1	Wait	Count to 20 before deciding a silence is a stall.
Rung 2	Ask an open question	<i>“What’s the worst thing that happens in your scenario?”</i> Redirects without supplying content.
Rung 3	Point at a card	Physically point at the Methods card and say nothing. Astonishingly effective.
Rung 4	State a rule	<i>“Remember you have to say which part of the threat each purchase touches.”</i>
Rung 5	Direct instruction	Only when time is nearly gone. Supplying an answer ends the learning for that team.

Triggers and thresholds

Signal	Threshold	What to do
Total stall, nobody speaking	60 seconds	Rung 2. <i>“Read your Methods card out loud and tell me who it hurts.”</i> Reading aloud restarts almost every stalled table.
One person doing all the talking	2 minutes	Rung 2, aimed at someone else: <i>“Which card would you defend that nobody has picked?”</i> Don’t name or silence the dominant speaker.
Agreement in under 90 sec	Immediate	Rung 2. Argue the other side: <i>“Make the case for the card you just dismissed.”</i> Fast consensus means the trade-off wasn’t felt.
Jargon others don’t share	First time	Rung 2, to the speaker: <i>“Say that again for someone who hasn’t taken a security course.”</i>
Buying without reference to the threat	2nd purchase	Rung 3: point at the Methods card. Then Rung 4: <i>“Which part of the scenario does that touch?”</i>
Overspending the budget	Immediate	Rung 4. Correct at once — the constraint is the mechanic.
Modifier played with no justification	Immediate	Rung 4. One prompt, then the card returns to the deck.
Threat moved to the top-left corner in Phase 3	Immediate	Rung 2. <i>“So this can’t happen at all now? What would an attacker with more time do?”</i>
<i>“Just tell us the right answer”</i>	After one deflection	Be honest: <i>“There’s a better and a worse answer, but not one right one. Tell me your reasoning and I’ll tell you where it’s weak.”</i>
Drifting into how to perform the attack	First time	Rung 4. <i>“We’re on the defending side of the table.”</i> No moralizing.
Finished 5+ minutes early	Immediate	Rung 2. <i>“Your budget was just cut by two tokens. What goes?”</i>
Running out of time	3 min left	Rung 5. Make them commit to a portfolio even if unfinished — incomplete is assessable, abandoned isn’t.

Four situations — act immediately, the ladder does not apply

- 1. Someone discloses a real vulnerability** at their employer, student org, or family business. **Stop it at the table:** *“Let’s not work through a real system in the open — come find me after.”* Follow up privately. A live vulnerability discussed in a room of twenty creates risk for a third party who didn’t consent.
- 2. A scenario lands on someone’s personal experience.** Human Impact includes Physical and Emotional Wellbeing; Methods includes Manipulation or Coercion. Stalking, doxxing, or intimate partner surveillance can hit hard. Watch for someone going quiet or leaving. **Offer an exit without requiring an explanation, addressed to the team, not the person:** *“This team can redraw the Impact card if you want a different scenario.”* Never require anyone to narrate aloud. Keep a redraw available every session as a standing, unremarkable option.
- 3. Someone is being spoken over or dismissed** — usually a non-major by a technical student. Fix it structurally, not socially: *“Let’s hear each person’s top card before anyone argues.”*
- 4. A factual error that will leave the room as a belief** — e.g. that encryption stops phishing, backups prevent a breach, or insurance removes the duty to notify. Correct briefly, without ceremony, then hand it back. Leave all other wrong answers to peers or the debrief.

Leave these alone

- Silence under 20 seconds. It’s thinking.
- Disagreement, including heated. It’s the mechanism — step in only if it turns personal.
- A defensible choice you wouldn’t have made. Ask why; don’t correct.
- A wrong answer a student is about to catch. Wait three seconds.
- A team ignoring a card you think is obviously right. Note it for debrief; steering purchases hollows out the exercise.
- Slightly unrealistic scenarios. Plausibility isn’t the objective.
- A team spending everything on one expensive card. Let Phase 3 teach it.

Self-check after your third session: Did teams argue? Did I go above Rung 2 more than twice per table? Did non-majors speak as much as majors? Did I supply an answer a peer would have given within five seconds?

Scenario Operations — Web Version

Everyone opens the same link

Facilitator adds #facilitator to the URL. Projector adds #projector. Players use the plain link. Add ?session=tue-am to run two classes at once — sessions are completely separate.

Starting a session

1. Open with #facilitator, pick a code, **Claim the role**. Write the code down — it is how you get the role back if your browser closes.
2. **Set the condition first** if you are collecting data. It locks the moment any team acts.
3. A fresh session **loads Scenario 1 automatically**. For another, pick it from the dropdown and press **Load**. Loading sets the organization, read-aloud text and budget, locks the threat model, and moves play to Phase 1.
4. Set **Teams** to about class size $\div 3$, rounded up.
5. Copy the player and projector links from **Links to share**.
6. Read the scenario aloud. Do not paraphrase — teams comparing notes later need to have heard the same words.

Two arms

Solutions	Measures list, then buy controls on a budget
Control	Measures list only. No cards, no budget

Everything else — guidance, timing, phases, interface — is identical. Both arms list the measures they would recommend, **including what they cannot afford**; that is what makes breadth comparable between them.

Separate sessions per arm:

?session=fall-a

?session=fall-b&condition=control

During play

- **Deal once** at Phase 2. Dealing again replaces every hand.
- **Timer** — one button starts the right length for the current phase. Everyone sees it, not just the projector.
- **Adjudication** — justifications queue with an amber badge. *Specific enough* or *Return to deck*. One prompt only.
- **Coverage stays hidden until Phase 3**, so teams cannot shop by watching what lights up.
- **Accessibility** — text size and light/dark sit in the header. Say so at the start; students rarely find them and some will not ask.

What each modifier asks

22	two purchases that fail differently
23	what happens when a control stops working
24	one access you'd cut (needs card 4 or 7 bought)
25	a purchase staff will work around, and how
26	a risk, and its named owner (instead of a purchase)
27	what you can't afford, and what the substitute misses
28	the exposure while you wait, and for how long

The expert key

Visible only to you, under the loaded scenario. It lists **strong**, **partial**, and **weak-here** controls.

Use it to follow the discussion, to know which trade-off the scenario was built around, and to score justifications afterwards.

Do not read it out, hint at it, or steer purchases toward it. A team that buys a “partial” card and defends it well has done better work than one that buys a “strong” card without reasoning. **Never show it to players.**

Ending

1. **Export CSV** first, always. Neither reset exports for you.
2. **New round** — clears threats, hands, placements, purchases; teams keep their seats. Use between scenarios with the same class.
3. **End session and clear board** — clears everything including team membership, archiving a copy first. Use at the end of class.
4. **Campaign play: do neither**. The same organization returns next week with drift applied.

Three things that go wrong

Two people on one team both clicking. The board is shared and the last write wins, so one set of changes silently overwrites the other. The app names a driver and warns everyone else. Agree who types before Phase 2.

Dealing twice. It replaces hands, including cards a team already bought. Deal once, at the start of Phase 2.

Clearing before exporting. *New round* does not archive. Export first or the round is gone.

Treating the two arms differently. If you explain more to a control team because they look stuck, you have compared a guided session with an unguided one and the study means nothing. Same scenario reading, same intervention rules, same manner. The software holds the interface constant; you hold yourself constant.

If the app misbehaves

The build version sits in grey beside *How to play*. If a student's differs from yours, they have a cached page — hard reload. A blank screen now shows a readable error instead; have them read the line to you.

If it fails outright, keep playing on paper. Every mechanic works with the physical deck, a printed 3×3 grid and six coins. Collect the record sheets instead of exporting.

Scenario Index

Full text, suggested draws and debrief questions: Appendix C of the Facilitator’s Manual. • = may land on personal experience; offer the redraw to the team *before* reading.

#	Organization	Bgt	Strongest controls	The trap
1	Harborview Food Bank <i>payroll redirection</i>	6	Social Engineering Awareness; Deepfake Awareness; Email & Browser	Teams rate severity by how clever the attack was. It is severe because \$18k is a month of cash.
2	Cedar Ridge Health Clinic <i>ransomware</i>	6	Backup & Recovery; Incident Response; EDR	The backup exists and is useless — it is on the same server. Prevention buys nothing here.
3 •	Wilder House shelter <i>stolen laptop</i>	6	Encryption; Physical Security; Identity & Access	A login password feels like protection. It is not.
4	Fairmount Land Trust <i>dormant account</i>	5	Account Lifecycle; Identity & Access	Nobody attacked anyone. The right answer is the dullest card in the deck.
5	Northbridge School District <i>vendor breach</i>	10	Third-Party & Contractual; Incident Response	Half the deck is useless — the district owns none of the affected systems.
6	Millbrook Water Authority <i>debug mode live</i>	10	Secure Configuration; Identity & Access	With ten points teams overspend. The fix costs one.
7 •	Eastgate Legal Aid <i>insider access</i>	10	Audit Logging & SIEM; Identity & Access + Least Privilege; MDR	Every preventive control fails. The access was authorized.
8	Delridge Public Library <i>unknown device</i>	6	Asset Inventory; Segmentation; Secure Configuration	Segmentation is out of reach at six points. What do you tell the board?
9	Ridgeway Arts Collective <i>unsupported software</i>	6	Software Inventory; Deferred Investment; Backup	Teams buy Software Updates. There are no patches — that is the problem.
10	Second Chance Rescue <i>shared mailbox</i>	10	Password & Authentication; Account Lifecycle; Incident Response	The shared password exists because it is genuinely convenient.

Choosing one

First session: 1, 2, 4 or 8. **Once they know the loop:** 5, 6, 7, 10. **Campaign play:** 9.

Vary the teaching target between sessions. If nobody bought logging last time, run 7, where detection is the only lever that works. If teams over-bought expensive cards, run 6, where a one-point card wins.

Never run a session against a real client’s systems. All ten organizations are fictional. If a participant starts describing a real vulnerability at a real place, stop it at the table and follow up privately — see page 2.